FADENA
FACULTAD DE DEFENSA NACIONAL

Universidad de la Defensa Nacional

Facultad de Defensa Nacional

Carrera: Lic. en Ciberdefensa

Materia
Sistemas Operativos II

Unidad 6 / Semana 12

Año: 2025

Contenidos

Concepto de seguridad informática. Disponibilidad, integridad y confidencialidad. Softwares malignos, ataques. Encriptación. Firmas y certificados digitales. VPN. Autenticación.

Índice

1. Seguridad de la Información **3**
1.1 Confidencialidad 3
1.2 Integridad 4
1.3 Disponibilidad 4
Normas y estándares internacionales 4
2. Seguridad Informática **5**
3. Software Maligno (Malware) **6**
Virus 7
Gusano (Worm) 7
Troyano (Trojan) 7
Spyware 7
Adware 7
Ransomware 8
Rootkit 8
Keylogger 8
Botnet 8
4. Encriptación o cifrado de datos **9**
Reseña Histórica 10
Encriptación de clave Simétrica 12
Funcionamiento 12
Ventajas 12
Desventajas 12
Ejemplos 12
Encriptación de clave Asimétrica 13
Funcionamiento 13
Caso 1 - Confidencialidad 13
Caso 2 - Prueba de Origen 13
Caso 3 - Confidencialidad y prueba de origen (signed) 14
Ventajas 14
Desventajas 14
Ejemplos 15
Esteganografía 15
7. Red Privada Virtual (VPN) **16**
8. Firmas y certificados digitales **17**
9. Certificado Digital **18**
El proceso básico de la firma digital 18
Autenticación **20**
Autenticación y proceso de Conexión del Usuario 21
1. Proceso de Conexión Inicial (Puesto de Trabajo) 21
2. Proceso de Conexión a una Aplicación Específica 21
Métodos de autenticación 22

1. Seguridad de la Información

La **seguridad de la información** comprende el conjunto de medidas preventivas y reactivas destinadas a preservar la *confidencialidad, integridad y disponibilidad* de los datos y/o información, independientemente de su formato o medio.

Incluye políticas, procedimientos y controles que regulan el tratamiento de la información, ya sea en el ámbito de una empresa, institución o persona particular.

La información puede ser almacenada, procesada o transmitida de diversas formas: electrónicamente, verbalmente o mediante soportes escritos o impresos. Por ello, la seguridad de la información abarca desde la protección física de un archivador con documentos sensibles, hasta la implementación de mecanismos técnicos para resguardar bases de datos digitales, redes o sistemas informáticos.

Hemos mencionado que la seguridad de la información se enfoca en tres características importantes que tiene la información, conocidas como **tríada C-I-D** (C-I-A por sus siglas en inglés):

- ➔ Confidencialidad
- ➔ Integridad
- ➔ Disponibilidad

Vamos a profundizar sobre estos aspectos.

1.1 Confidencialidad

La confidencialidad se refiere a la prevención de la divulgación de información a personas o sistemas no autorizados.

Responde a la pregunta clave : **¿quién puede acceder a esta información?**

La pérdida de la confidencialidad de la información se puede dar de muchas formas:

- Cuando alguien mira por encima de su hombro, mientras alguien tiene información confidencial en la pantalla,
- cuando se publica información privada,
- cuando un laptop con información sensible sobre una empresa es robado,
- cuando se divulga información confidencial a través del teléfono,
- o conversaciones privadas en lugares públicos, etc.

Todos estos casos pueden constituir una violación de la confidencialidad, entre otros.

1.2 Integridad

La integridad de la información es la propiedad de la información que garantiza que los datos se mantengan exactos, completos y confiables a lo largo de su ciclo de vida. Su propósito es evitar modificaciones no autorizadas, errores involuntarios o alteraciones maliciosas que puedan comprometer la veracidad de la información.

Responde a la pregunta clave : **¿Es esta información confiable?**

1.3 Disponibilidad

Por último, la disponibilidad es la característica que asegura que la información y los sistemas estén accesibles y operativos cuando se los necesite.

Responde a la pregunta clave : **¿Puedo acceder a la información cuando la necesito?**

Normas y estándares internacionales

La seguridad de la información ha estado presente desde los albores de las civilizaciones, de manera implícita, cada vez que existió la necesidad de proteger secretos, conocimientos estratégicos o información sensible. Con el paso del tiempo y el avance de la tecnología, esta necesidad se ha intensificado, dando lugar al desarrollo de normas, estándares y marcos regulatorios que permiten a las organizaciones establecer políticas, procedimientos y controles sistemáticos para resguardar la información que gestionan a diario. Así, la seguridad de la información ha evolucionado desde prácticas intuitivas hasta convertirse en una disciplina formal, esencial para garantizar que la información tenga la confidencialidad, integridad y disponibilidad de los datos necesarios en entornos cada vez más complejos y digitalizados.

Podemos mencionar a la familia de **normas *ISO/IEC 27000***, que establece un marco internacional para la gestión de la seguridad de la información, abarcando desde políticas organizativas hasta controles técnicos específicos. Su núcleo es la norma ISO/IEC 27001, que define los requisitos para implementar un **Sistema de Gestión de Seguridad de la Información (SGSI)**, aplicable a cualquier tipo de organización. Esta norma se complementa con otras como la ISO/IEC 27002, que detalla buenas prácticas y controles para proteger la confidencialidad, integridad y disponibilidad de los datos, y la ISO/IEC 27005, que aborda la gestión de riesgos asociados a los activos informativos, la ISO/IEC 27701 que aplica al ámbito de la privacidad y protección de datos personales y la ISO/IEC 27032 que se enfoca en la ciberseguridad.

Entre todas estas normas, la única certificable es la ISO/IEC 27001 mientras que las otras son de apoyo y brindan un marco de referencia.

2. Seguridad Informática

La Seguridad Informática es una parte de la *seguridad de la información* cuyo objeto es la *información almacenada y procesada en computadoras o redes de computadoras.*

Por lo tanto, la **seguridad informática** se refiere entonces a la *Confidencialidad*, *Integridad* y *Disponibilidad* de la información y datos cuando éstos están almacenados y/o **procesados en sistemas informáticos,** es decir **digitalizados**.

En relación con la seguridad informática y las normas previamente mencionadas ISO/IEC 27000, podemos mencionar que incluyen aspectos técnicos como cifrado, autenticación, gestión de accesos, protección contra malware y seguridad en redes, todos ellos esenciales para resguardar los sistemas digitales, además de los otros aspectos ya mencionados de la seguridad de la información.

Cuadro de amenazas y prevención según CID

Aspecto	Amenazas comunes	Medidas de prevención
Confidencialidad	- Acceso no autorizado - Robo de credenciales - Divulgación accidental - Ingeniería social - Robo/pérdida de dispositivos	- Uso de SO seguros y confiables - Control de accesos y privilegios - Autenticación multifactor (MFA) - Cifrado de datos en tránsito y reposo - Capacitación en buenas prácticas y phishing
Integridad	- Alteración maliciosa de datos - Errores humanos en carga o edición de datos / Desarrollo de apps - Manipulación de registros - Fallos en sincronización de sistemas	- Validaciones automáticas y controles de entrada - Registros de auditoría y trazabilidad - Control de versiones - Hashing y firmas digitales - Uso de SO seguros y confiables - Políticas de QA en desarrollo - Monitoreo activo y antivirus actualizado
Disponibilidad	- Ataques de denegación de servicio (DoS) - Fallos de hardware o software - Interrupciones eléctricas o desastres naturales - Malware que bloquea el acceso	- Backups periódicos y pruebas de restauración - Infraestructura redundante y balanceo de carga - Planes de continuidad y recuperación ante desastres - Monitoreo activo y antivirus actualizado

3. Software Maligno (Malware)

El término **malware** (abreviatura de *malicious software*) se refiere a cualquier tipo de programa o código malicioso diseñado para infiltrarse, dañar, alterar o robar información de un sistema informático sin el consentimiento del usuario.

Los *malware* pueden afectar la confidencialidad, integridad y disponibilidad de los sistemas informáticos, y suelen aprovechar vulnerabilidades en software, redes o prácticas inseguras.

Existen varias categorías de malware:

Virus

Un *virus informático* es un tipo de malware que se adhiere a archivos ejecutables o documentos y se activa cuando el archivo huésped es abierto o ejecutado por el usuario. Su comportamiento es similar al de un virus biológico: se replica y propaga a otros archivos o sistemas, causando daños como la corrupción de datos, ralentización del sistema o incluso la destrucción de archivos críticos. Los virus requieren intervención humana para propagarse, como compartir archivos infectados por correo o dispositivos extraíbles. Su detección y eliminación suele requerir software antivirus actualizado y buenas prácticas de higiene digital.

Gusano (Worm)

A diferencia de los virus, los gusanos no necesitan un archivo huésped ni intervención del usuario para propagarse. Se replican automáticamente a través de redes, aprovechando vulnerabilidades en sistemas operativos no seguros o servicios mal configurados. Su principal objetivo suele ser consumir recursos del sistema o de la red, provocando congestión, caídas de servicios o incluso la creación de puertas traseras para otros ataques. Algunos gusanos también descargan otros tipos de malware, como troyanos o ransomware, una vez que infectan un sistema.

Troyano (Trojan)

Un troyano es un tipo de malware que se presenta como un programa legítimo o inofensivo para engañar al usuario y lograr que lo instale. Una vez dentro del sistema, puede abrir puertas traseras (backdoors) que permiten el acceso remoto a atacantes, robar información confidencial, registrar pulsaciones del teclado o descargar otros programas maliciosos. A diferencia de los virus o gusanos, los troyanos no se replican por sí solos, pero su capacidad de camuflaje los hace especialmente peligrosos en entornos donde los usuarios no están entrenados para identificar software sospechoso.

Spyware

El spyware es un software malicioso diseñado para espiar al usuario sin su conocimiento. Su función principal es recopilar información personal, como hábitos de navegación, credenciales de acceso, datos bancarios o contenido de correos electrónicos. Esta información puede ser utilizada para fines publicitarios, fraude o robo de identidad. El spyware suele instalarse junto con software gratuito o mediante vulnerabilidades del navegador, y puede degradar el rendimiento del sistema al ejecutarse en segundo plano de forma persistente.

Adware

El adware es un tipo de software que muestra anuncios no deseados en el dispositivo del usuario, generalmente con fines comerciales. Aunque no siempre

es malicioso, muchos adware invaden la privacidad del usuario al recolectar datos sin consentimiento o redirigir el navegador a sitios publicitarios. En algunos casos, el adware puede actuar como puerta de entrada para otros tipos de malware más peligrosos. Su presencia suele manifestarse en forma de ventanas emergentes, cambios en la página de inicio del navegador o instalación de extensiones no autorizadas.

Ransomware

El ransomware es uno de los tipos de malware más destructivos y lucrativos para los atacantes. Su funcionamiento consiste en cifrar los archivos del sistema infectado y exigir un rescate económico (generalmente en criptomonedas) a cambio de la clave de descifrado. Si la víctima no paga, puede perder el acceso a sus datos de forma permanente. Este tipo de ataque ha afectado a empresas, hospitales, universidades y gobiernos, generando pérdidas millonarias. La prevención incluye copias de seguridad frecuentes, actualizaciones de seguridad y formación del personal.

Rootkit

Un rootkit es un conjunto de herramientas diseñadas para ocultar la presencia de malware u otras actividades maliciosas dentro de un sistema operativo. Su objetivo es mantener el acceso privilegiado al sistema sin ser detectado por el usuario o por los mecanismos de seguridad. Los rootkits pueden modificar funciones del sistema, ocultar procesos, archivos o claves del registro, y desactivar antivirus. Debido a su capacidad de camuflaje a bajo nivel, suelen ser difíciles de detectar y eliminar, y en muchos casos requieren reinstalar el sistema operativo. Pueden ser de firmware, hipervisor, kernel, biblioteca o aplicación.

Keylogger

Un keylogger es un tipo de malware que registra todas las pulsaciones del teclado realizadas por el usuario. Esta información puede incluir nombres de usuario, contraseñas, números de tarjetas de crédito y otros datos sensibles. La información colectada es luego enviada a sitios remotos bajo control del atacante. Los keyloggers pueden ser utilizados por ciberdelincuentes para realizar fraudes, acceder a cuentas bancarias o robar identidades. Pueden instalarse como parte de un troyano o mediante vulnerabilidades en el sistema. Su detección requiere herramientas especializadas, ya que suelen operar de forma silenciosa y persistente.

Botnet

Una *botnet* es una red de dispositivos infectados (bots o zombies) que son controlados remotamente por un atacante, conocido como botmaster. Estos dispositivos pueden ser utilizados para realizar ataques coordinados, como DDoS (Denegación de Servicio Distribuida), envío masivo de spam, minería de

criptomonedas o distribución de malware. Los usuarios afectados generalmente no son conscientes de que sus equipos están comprometidos. Las botnets representan una amenaza significativa para la infraestructura de internet y requieren estrategias de detección a nivel de red y colaboración entre organizaciones para su desmantelamiento.

4. Encriptación o cifrado de datos

El cifrado es un proceso dentro de la criptografía que consiste en **transformar datos legibles (texto plano)** en una **forma ilegible (texto cifrado)** mediante el uso de un algoritmo y una clave. Su objetivo principal es proteger la confidencialidad de la información, de modo que *solo las personas o sistemas autorizados puedan acceder al contenido original*.

Para cualquier otro observador, el *texto cifrado* no es más que una secuencia incomprensible de bits o caracteres.

Aunque pueda parecer sorprendente a primera vista, los algoritmos de cifrado y descifrado *suelen ser públicos*. Pretender mantenerlos en secreto genera una falsa sensación de seguridad, práctica conocida como *seguridad por oscuridad*, común entre aficionados e incluso algunas grandes corporaciones que no adhieren a los estándares más actualizados.

En criptografía moderna, el secreto no reside en el algoritmo sino en los parámetros que utiliza, conocidos como **claves**. Si denotamos el *texto plano* como **P**, la *clave de cifrado* como **KE**, el *texto cifrado* como **C**, y el *algoritmo de cifrado* como **E**, entonces el proceso se expresa como:

$$C = E(P, KE)$$

Esto significa que el texto cifrado C se obtiene aplicando el algoritmo E al texto plano P utilizando la clave KE. Este enfoque responde al **Principio de Kerckhoffs**, formulado en el siglo XIX por el criptógrafo holandés Auguste Kerckhoffs, y ampliamente aceptado por la comunidad criptográfica actual.

De forma análoga, el proceso de descifrado se representa como:

$$P = D(C, KD)$$

donde **D** es el *algoritmo de descifrado* y **KD** la clave correspondiente. Es decir, para recuperar el *texto original* **P** a partir del *texto cifrado* **C**, se aplica *el algoritmo* D utilizando la *clave de descifrado* KD. La figura 1 ilustra la relación entre estos elementos.

Los cifradores se clasifican según su funcionamiento en

- Cifradores de flujo (stream cipher)
  Implementados usualmente en hardware y son útiles en comunicaciones seriales.
- Cifradores de bloques (block cipher)
  Operan con bloques fijos de texto plano y son los más utilizados actualmente.

En general los algoritmos de cifrado se utilizan porque nos ayudan a resolver el problema de la confidencialidad mencionado anteriormente, pero algunos de ellos nos permiten además:

1. *Prueba de Origen*:
   Es la capacidad de verificar que un mensaje proviene realmente del emisor que dice haberlo enviado. Es decir, permite autenticar la fuente del mensaje.
2. *No Repudio*:
   Es la garantía de que el emisor no puede negar haber enviado el mensaje. Es decir, se evita que una parte involucrada en una comunicación repudie su participación. Tiene soporte legal en muchos países

Esto se logra con el cifrado de claves asimétricas y/o firmas digitales uqe vere

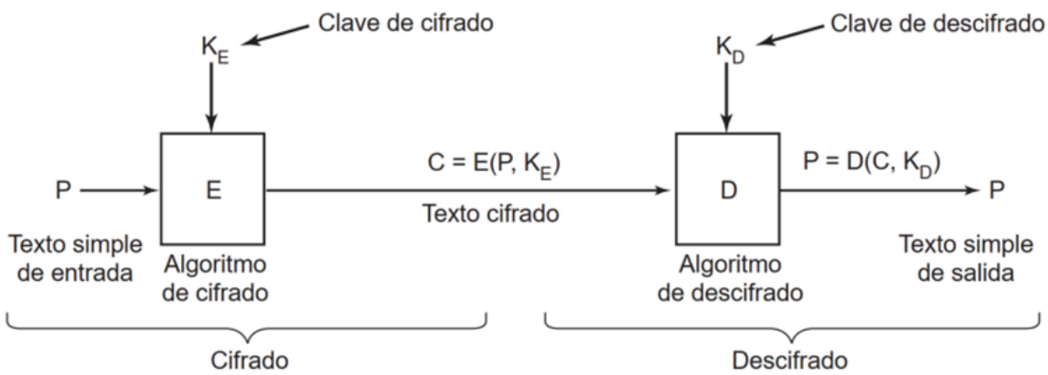


Figura 1. Cifrado y Descifrado[1]

Reseña Histórica

La criptografía nace como necesidad de proteger mensajes en contextos militares y diplomáticos. Civilizaciones como Egipto, Grecia y Roma desarrollaron sistemas rudimentarios de cifrado:

[1] Tanenbaum, A. S. (2009). Sistemas operativos modernos (3ª ed.). Pearson Prentice Hall.

- Jeroglíficos egipcios: aunque no eran cifrados en sentido técnico, su complejidad dificultaba la interpretación
- Scytale espartana: método de transposición que reorganizaba letras en tiras enrolladas sobre cilindros.
- Cifrado César: desarrollado por Julio César, desplazaba letras del alfabeto un número fijo de posiciones. Es uno de los primeros ejemplos de cifrado por sustitución.

Edad Media y Renacimiento

Durante siglos, el cifrado se mantuvo como una práctica artesanal:

- Cifrado por sustitución polialfabética: introducido por Leon Battista Alberti en el siglo XV, usaba múltiples alfabetos para dificultar el análisis de frecuencia.
- Disco de cifrado de Vigenère: popularizado en el siglo XVI, se consideró "indescifrable" durante siglos, aunque fue quebrado en el siglo XIX.

Siglo XX: la era mecánica y electrónica

La criptografía se industrializa y se vuelve estratégica:

- Máquina Enigma: usada por Alemania en la Segunda Guerra Mundial. Su descifrado por Alan Turing y el equipo de Bletchley Park fue clave para los Aliados.
- DES (Data Encryption Standard): adoptado en 1977 por EE.UU. como estándar de cifrado simétrico. Usaba bloques de 64 bits y claves de 56 bits.
- 3DES (Triple DES): mejora de DES que aplicaba el algoritmo tres veces para aumentar la seguridad.

Criptografía moderna y digital

Con la llegada de la informática, los algoritmos se vuelven más sofisticados:

- RSA (1977): primer algoritmo de cifrado asimétrico ampliamente usado. Basado en la factorización de números primos grandes.
- AES (Advanced Encryption Standard): reemplazó a DES en 2001. Usa claves de 128, 192 o 256 bits y es el estándar actual para cifrado simétrico.
- PGP (Pretty Good Privacy) creado en 1991 y publicado como freeware
- ECC (Elliptic Curve Cryptography): ofrece seguridad similar a RSA con claves más pequeñas, ideal para dispositivos móviles.

Encriptación de clave Simétrica

El cifrado simétrico también conocido como clave privada o clave secreta utiliza **una única clave para cifrar y descifrar la información**. Tanto el emisor como el receptor deben compartir esta clave de forma segura antes de iniciar la comunicación.

Funcionamiento

- El emisor aplica un algoritmo de cifrado al mensaje usando la clave compartida.
- El receptor aplica el mismo algoritmo (en modo inverso) con la misma clave para recuperar el mensaje original.

Ventajas

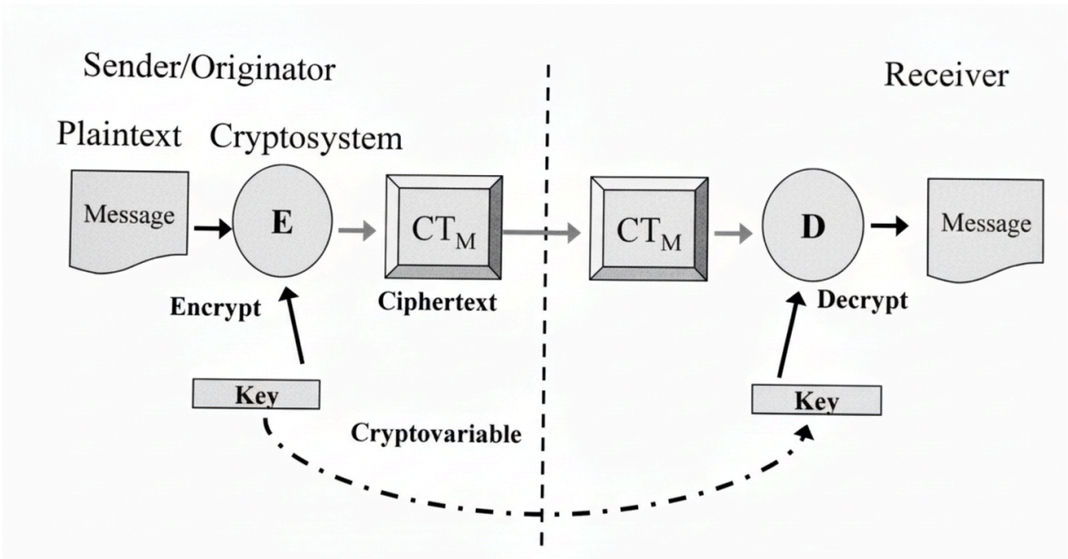
- Muy rápido y eficiente para grandes volúmenes de datos.
- Ideal para cifrado de discos, VPNs, y comunicaciones en tiempo real.
- Muy difícil de quebrar cuando las claves son grandes
- Hay algoritmos y herramientas libres para usar

Desventajas

- Requiere un canal seguro para compartir la clave.
- Si la clave se compromete, todo el sistema queda vulnerable.
- Mensaje y clave deben ser entregados en forma separadas
- No asegura *prueba de origen* ni *no repudio*

Ejemplos

Blowfish / DES / 3DES / IDEA / RC4 / SAFER



Cifrado de clave simétrica

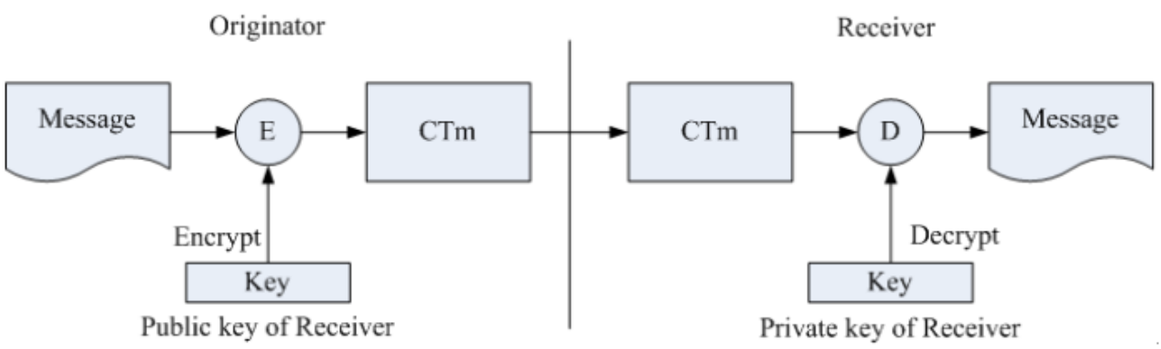
Encriptación de clave Asimétrica

El cifrado asimétrico o encriptación de clave asimétrica requiere del uso de un par de claves, *una clave pública*, que es de conocimiento público y *otra privada*, que sólo el propietario debe conocer. Ambas claves están relacionadas porque una se deriva matemáticamente de la otra.

Funcionamiento

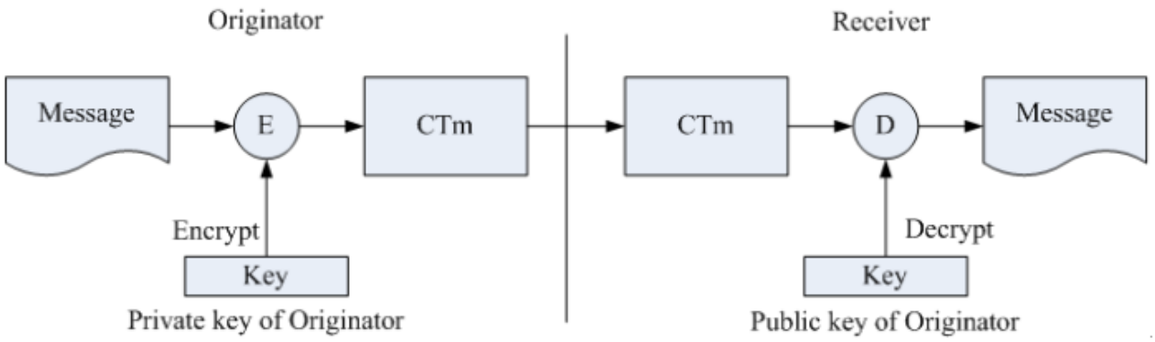
Caso 1 - Confidencialidad

- El emisor cifra el mensaje usando la clave pública del receptor.
- Solo el receptor, con su clave privada, puede descifrar el mensaje, garantizando la confidencialidad del mensaje



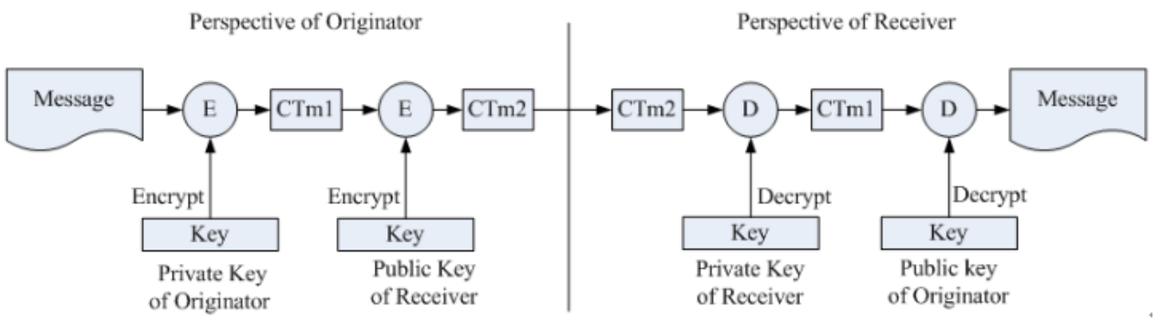
Caso 2 - Prueba de Origen

- El emisor aplica un algoritmo de cifrado al mensaje usando su clave privada
- El receptor descifra el mensaje usando la clave pública del emisor, asegurando que el emisor fue quien envió el mensaje



Caso 3 - Confidencialidad y prueba de origen (signed)

- El emisor aplica un algoritmo de cifrado al mensaje usando su clave privada
- Luego el emisor aplica el algoritmo de cifrado ahora usando la clave pública del receptor y envía el mensaje
- El receptor recibe el mensaje cifrado y lo descifra usando primero su clave privada primero y,
- Luego descifra el mensaje usando la clave pública del emisor, obteniendo el mensaje original con la prueba de origen



Ventajas

- Provee confidencialidad y prueba de origen.
- Distribución eficiente de claves
- Mejor escalabilidad respecto a la simétrica, requiere menor cantidad de claves

Desventajas

- Es más lenta que la simétrica
- No es eficiente en grandes volúmenes de información

Ejemplos

RSA / ECC / DSA / ElGamal

Esteganografía

La esteganografía es el arte y la ciencia de ocultar información dentro de otro objeto o medio, de forma que no sea evidente que hay un mensaje oculto. A diferencia de la criptografía, que transforma el contenido para hacerlo ilegible, la esteganografía disimula la existencia misma del mensaje.

Si bien es no exactamente un método de cifrado porque no hace ilegible al mensaje, es una forma de asegurar la confidencialidad en cierta forma.

En la esteganografía digital, los datos ocultos se insertan en archivos multimedia (imágenes, audio, video, texto) aprovechando espacios o estructuras que no afectan la apariencia o funcionalidad del archivo original. Por ejemplo:

- En una imagen, se pueden modificar los **bits menos significativos (LSB)** de cada píxel para insertar información sin alterar visualmente la imagen.
- En un archivo de audio, se pueden alterar frecuencias imperceptibles al oído humano.
- En un texto, se pueden usar **espacios invisibles**, errores ortográficos intencionales o patrones de formato.

El autor Andrew S. Tanenbaum provee un ejemplo de este sistema (LSB) en su libro[2] que se puede encontrar en este link:
https://www.cs.vu.nl/~ast/books/mos2/zebras.html

Información adicional:
https://latam.kaspersky.com/resource-center/definitions/what-is-steganography

[2] Tanenbaum, A. S. (2009). Sistemas operativos modernos (3ª ed.). Pearson Prentice Hall. pág.640

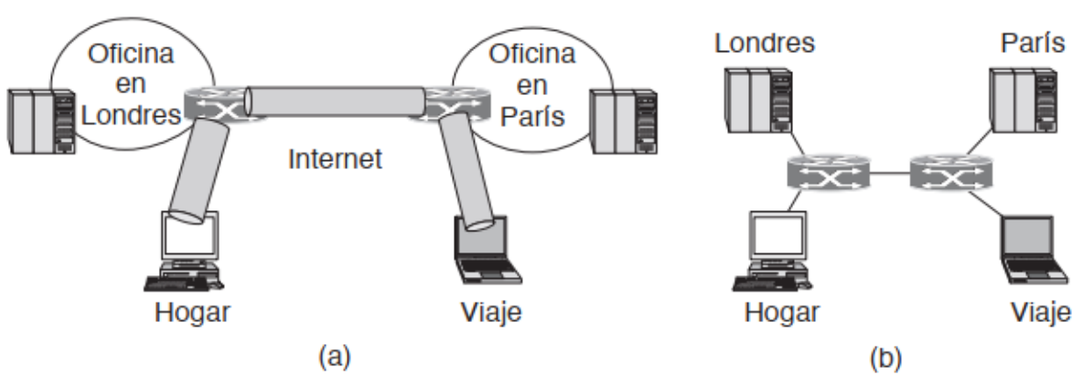
7. Red Privada Virtual (VPN)

Una **Red Privada Virtual (VPN)** (del inglés *Virtual Private Network*), **se define** como el tipo de red que **permite la extensión** de una red local sobre una red pública o no controlada, como por ejemplo **Internet**.

Las VPN surgen ante la necesidad de las organizaciones o **corporaciones** de proveer a su personal con la capacidad de acceder a su infraestructura de red interna, o **Intranet**, desde cualquier lugar y **en cualquier momento, de forma segura**. Así, las **VPN** se establecen como redes privadas que utilizan la infraestructura de **Internet** para el transporte de datos, implementando técnicas de seguridad para mantener la **confidencialidad** de los datos que se **transmiten** entre los usuarios.

Un método popular es construir redes VPN directamente sobre Internet. Un diseño común es equipar cada oficina con un firewall y crear túneles a través de Internet entre todos los pares de oficinas.

Una ventaja adicional de usar Internet para la conectividad es que los túneles se pueden establecer bajo demanda para incluir, por ejemplo, la computadora de un empleado que se encuentra en su hogar o de viaje, siempre y cuando tenga conexión a Internet (ver esquema parte a). Esta flexibilidad es mucho mayor de la que proveen las líneas alquiladas sin embargo, desde la perspectiva de las computadoras en la VPN, la topología es igual a la del caso de la red privada (ver esquema parte b).[3]



(a) Una red privada virtual. (b) La topología vista desde el interior.[4]

[3] Tanenbaum, Andrew S. (2012): Redes de Computadoras. Ed. Pearson, 2012. Quinta Edición
[4] Tanenbaum, Andrew S. (2012): Redes de Computadoras. Ed. Pearson, 2012. Quinta Edición

Lectura complementaria: ¿Para qué sirve una Red Privada Virtual y qué ventajas aporta? | Incibe



8. Firmas y certificados digitales

La firma digital o electrónica es un conjunto de datos electrónicos que acompañan o que están asociados a un documento electrónico y cuyas funciones básicas son:[5]

- Identificar al firmante de manera inequívoca.
- Asegurar la integridad del documento firmado. Asegura que el documento firmado es exactamente el mismo que el original y que no ha sufrido alteración o manipulación.
- Asegurar el no repudio del documento firmado. Los datos que utiliza el firmante para realizar la firma son únicos y exclusivos y, por tanto, posteriormente, no puede decir que no ha firmado el documento.

¿Qué utilidad práctica tiene la firma digital?

Aporta tres características en la comunicación por Internet: identificación del firmante, integridad de los datos y no repudio.

Pero a parte de eso, las aplicaciones prácticas de la misma son muchas y variadas.

En general están orientadas a realizar operaciones por Internet que en la vida cotidiana requieren de una firma para validarlas.

Algunos ejemplos de operaciones que se pueden realizar actualmente haciendo uso de la firma digital son:[6]

- Realización de la Declaración de la Renta a través de Internet.
- Solicitudes en los registros electrónicos administrativos
- Solicitar el informe de vida laboral.

[5] Gobierno de España. (s.f.). *La firma electrónica*. Sede Electrónica del Gobierno de España. Recuperado de https://firmaelectronica.gob.es/ciudadanos/cosas-deberias-saber/firma-electronica
[6] Gobierno de España. (s.f.). *La firma electrónica*. Sede Electrónica del Gobierno de España. Recuperado de https://firmaelectronica.gob.es/ciudadanos/cosas-deberias-saber/firma-electronica

- Recepción de notificaciones electrónicas.
- Firma de correos electrónicos.
- Firma de facturas electrónicas.

9. Certificado Digital

La **firma digital** de cualquier documento requiere obligatoriamente que el usuario posea un **certificado digital** o un **DNI electrónico**. Estos elementos son fundamentales porque **contienen las claves criptográficas** necesarias para ejecutar el proceso de firma.

El objetivo principal del certificado electrónico es **identificar de manera inequívoca** a su titular. Estos certificados son expedidos por **proveedores de servicios de certificación**.



El certificado digital es un archivo firmado con la clave privada de una autoridad de certificación y que contiene la clave pública de dicha identidad y los atributos del titular del certificado.

Actividad: Realiza los siguientes pasos para ver el certificado digital correspondiente al sitio del campus de FADENA.

Pasos:

1. Ingresa al sitio https://campus.fadena.undef.edu.ar/
2. Clic en el candado en la parte izquierda de la barra de direcciones del navegador.
3. Clic en Conexión segura y en Más información.
4. En la pestaña Seguridad, debe hacer clic en el botón Ver certificado.
5. Verá una página con los datos del certificado.

El proceso básico de la firma digital

El proceso comienza cuando el usuario dispone de un documento electrónico (como un archivo PDF, una imagen, una hoja de cálculo o un formulario web) y del certificado que le pertenece y lo identifica.

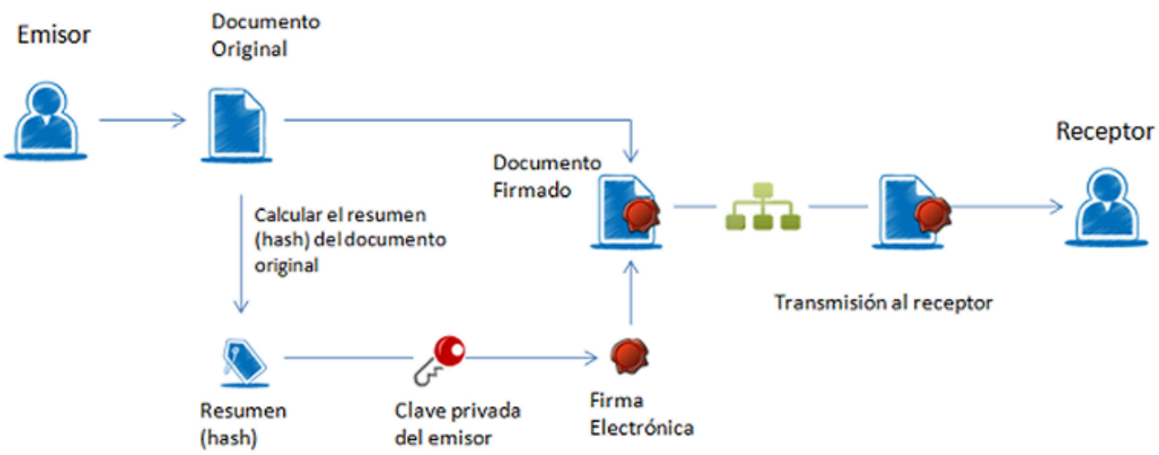
El proceso de firma sigue los siguientes pasos:

1. **Generación del resumen (Hash):** La aplicación o el dispositivo digital utilizado para la firma realiza un **resumen** del documento original. Este

resumen es una representación de datos significativamente más pequeña (pudiendo ser tan solo de unas líneas, incluso si el documento original es de gran tamaño). Es crucial entender que este resumen es **único**: cualquier modificación, por pequeña que sea, realizada en el documento original resultará en una modificación distinta del resumen.

2. **Codificación con clave privada:** La aplicación utiliza la **clave privada** del firmante para **codificar** este resumen único.
3. **Creación de la firma:** A partir del resumen codificado, la aplicación genera un **nuevo documento electrónico**. Este documento resultante, que contiene el resumen cifrado, es la **firma digital.**.

El resultado final es un documento electrónico compuesto a partir del documento original y de las claves del firmante. Por lo tanto, **la firma electrónica es el documento electrónico resultante de este proceso**.



Proceso básico de la Firma Digital[7]

El esquema de la firma electrónica es un método para **demostrar quién firma** y **garantizar que el documento no ha sido alterado** después de la firma.

1. **Requisito inicial (Identificación):** Para empezar a firmar, usted debe tener un certificado digital o DNI electrónico, que es como su cédula de identidad digital. Este certificado contiene las claves secretas (criptográficas) necesarias.
2. **La "Huella Digital" del documento:** La aplicación de firma toma el documento y calcula una **"huella digital" o resumen**. Esta huella es cortísima, pero funciona como un código único para ese documento. Si alguien cambia una coma en el texto, el código de la huella cambia por completo.
3. **El sello secreto:** La aplicación usa su **clave privada** (la parte secreta de su certificado) para **sellar o codificar** esa huella digital.

[7] Fuente: La firma electrónica, por el Gobierno de España, s.f. (https://firmaelectronica.gob.es/ciudadanos/cosas-deberias-saber/firma-electronica).

4. **Resultado final:** El resultado de sellar la huella digital es un nuevo archivo adjunto. **Ese archivo adjunto es su firma digital**. Al final, usted tiene un documento electrónico que prueba que usted, con sus claves, selló ese contenido específico.

Autenticación

Autenticación:
Requiere que el sistema informático sea capaz de verificar la identidad de los usuarios.

La autenticación en el ámbito tecnológico se define como la acción mediante la cual demostramos a otra persona o sistema que somos quien realmente decimos ser. Los mecanismos para autenticarnos, bien sea con una contraseña, con biometría o con otros dispositivos o aplicaciones, se han ido convirtiendo poco a poco, debido en parte al avance de la digitalización, en una de las piedras angulares para la ciberseguridad de cualquier negocio. Así, es la autenticación la que permite el acceso a nuestros sistemas. Pero no está exenta de riesgos que pueden comprometer la información y los procesos a los que dan acceso.[8]

Con relación a los roles en el proceso de autenticación la verificación de identidad digital intervienen dos partes fundamentales:

- **Remitente:** Se refiere al usuario, programa o dispositivo (máquina) que busca establecer una conexión con un sistema que requiere identificación.
- **Verificador:** Es la parte responsable de validar la identidad digital del remitente que solicita el acceso al sistema.

¿Por qué es importante una autenticación segura?

Siempre que se habla de buenas prácticas en ciberseguridad, destacan dos puntos clave en relación a una autenticación segura: el control de acceso a las aplicaciones críticas y áreas restringidas y la gestión de claves de forma segura. Cumplir con estas dos cuestiones es fundamental para velar adecuadamente por la ciberseguridad de cualquier tipo de negocio, ya que su vulnerabilidad puede provocar incidentes graves de seguridad, como que un tercero no autorizado acceda a información confidencial de la empresa.[9]

[8] INCIBE. (2021, noviembre 9). TemáTICas: autenticación segura, ¿qué es y por dónde empiezo? Instituto Nacional de Ciberseguridad. https://www.incibe.es/empresas/blog/tematicas-autenticacion-segura-y-donde-empiezo
[9] INCIBE. (s.f.). TemáTICas: Autenticación. Instituto Nacional de Ciberseguridad. https://www.incibe.es/empresas/tematicas/autenticacion

Autenticación y proceso de Conexión del Usuario

La **autenticación** es el paso inicial y fundamental en el proceso de conexión de cualquier usuario a un sistema informático.

Toda organización que dependa de un sistema de información debe garantizar un proceso de conexión seguro a sus sistemas y aplicaciones. Los dos pilares esenciales de una infraestructura sólida de **Gestión de Identidades y Accesos (IAM)** son:

1. La creación de una **fuente única y fiable de identidades**.
2. La **gestión rigurosa de los derechos** asociados a esas identidades.

Una vez establecidos estos pilares, el proceso de conexión de un usuario se efectúa y se articula generalmente en cuatro etapas:

1. Proceso de Conexión Inicial (Puesto de Trabajo)

Etapa	Descripción
1. Autenticación del Puesto	El usuario inicia una sesión en el puesto de trabajo y se autentica (demuestra su identidad).
2. Conexión a Recursos	El sistema comprueba los derechos del usuario y le concede acceso a sus recursos (archivos, impresoras, red, etc.).

2. Proceso de Conexión a una Aplicación Específica

Etapa	Descripción
1. Autenticación en la Aplicación	El usuario ejecuta una aplicación y se autentica nuevamente dentro de esta aplicación (si es necesario).
2. Conexión a Transacciones y Datos	La aplicación comprueba los derechos específicos del usuario y le conecta a sus transacciones y datos.

La **autenticación del usuario** es el punto fundamental de todo este proceso. Es la encargada de permitir que el Sistema de Información **verifique la identidad** del usuario y, consecuentemente, le **asocie los derechos** de acceso adecuados.

Es importante señalar que existen **numerosos métodos de autenticación**, cada uno de los cuales posee sus características y niveles de seguridad específicos.

Métodos de autenticación

Una autenticación puede efectuarse mediante diversos mecanismos, los cuales se clasifican según el tipo de información que el sistema requiere del usuario para confirmar su identidad. Tradicionalmente, se distinguen tres factores principales:

1. **Autenticación por conocimiento (Algo que sabes)**: El remitente proporciona información confidencial que solo él conoce. Ejemplo: contraseñas, PIN o preguntas de seguridad.
2. **Autenticación por posesión (Algo que tienes)**: El remitente debe poseer un objeto físico o un token que sirve para identificar su identidad. Ejemplo: una tarjeta inteligente, una tarjeta de coordenadas, llaves de seguridad USB (tokens) o un código enviado al teléfono móvil.
3. **Autenticación por característica física (Algo que eres)**: La persona utiliza un rasgo físico o biológico único para identificarse. Para ello, es necesario emplear algún dispositivo biométrico que verifique estas características. Ejemplo: Verificación de huella dactilar, reconocimiento de voz o escaneo de iris/retina.

Es importante aclarar que esta clasificación es la base de la **Autenticación Multifactor (MFA)**, que se consigue al combinar dos o más de estos factores para aumentar significativamente la seguridad.